Critérios de Avaliação e Rubrica Projeto Final (Turma 1746)

Projeto Final DevSecOps Clube Aurora

A nota final é calculada em uma escala de **0 a 100 pontos**, rigorosamente adaptada aos objetivos pedagógicos de cada trilha (**Nível 1 Teórica Guiada, Nível 2 Misto e Nível 3 Técnica**).

[MÉTRICAS] Matriz de Pesos por Nível de Atuação

Critério de Avaliação	Nível 1 (Teórica Guiada)	Nível 2 (Misto)	Nível 3 (Técnica)	Evidência Concreta Esperada
1. Identificação e Diagnóstico das Falhas	25 pts	20 pts	15 pts	Mapeamento exato de onde está o problema (arquivo e linha), ferramentas responsáveis e categorias STRIDE/CWE correspondentes.
2. Correção Prática (Código e Pipeline)	*N/A (0 pts)*	30 pts	45 pts	Alterações no código-fonte, commits atômicos, Pull Request aberto e steps do GitHub Actions passando com status verde.
3. Compreensão do Impacto no Negócio (CIA)	40 pts	20 pts	10 pts	Tradução técnica dos riscos para a realidade do Clube Aurora (LGPD, vazamento de clientes VIP, extorsão e perda de reputação).
4. Governança, RBAC & Menor Privilégio	25 pts	20 pts	20 pts	Argumentação consistente e memorando técnico recusando o admin total para Carla e Tio Armando, propondo modelo RBAC e SoD.
5. Clareza, Organização e Evidências	10 pts	10 pts	10 pts	Relatório em Markdown bem formatado, links funcionais do GitHub, prints legíveis dos scanners e respeito às convenções.

Critério de Avaliação	Nível 1 (Teórica Guiada)	Nível 2 (Misto)	Nível 3 (Técnica)	Evidência Concreta Esperada
PONTUAÇÃO TOTAL	**100 pts**	**100 pts**	**100 pts**	Soma de todos os critérios aplicáveis ao nível escolhido.

[RELATÓRIO] Descrição dos Níveis de Desempenho

1. Identificação e Diagnóstico das Falhas

- **Excelente (100% dos pontos):** Mapeia com precisão cirúrgica a causa-raiz de cada falha, citando ferramentas (Semgrep, Trivy, Hadolint, ZAP), arquivos afetados e classificando corretamente em STRIDE.
- **Parcial (50% dos pontos):** Aponta o sintoma visível, mas confunde a causa técnica ou erra a ferramenta detectora.
- **Insuficiente (0% dos pontos):** Não identifica as falhas principais ou apresenta explicações desconexas.

2. Correção Prática (Código & Pipeline)

- **Excelente (100% dos pontos):**
- *No Nível 2:* F1, F2 e F4 corrigidos com código limpo e steps de Hadolint e Trivy FS 100% verdes.
- *No Nível 3:* Todas as 7 falhas (F1 a F7) corrigidas, testes unitários passando (`pytest -v`), Pipeline Estática e Dinâmica 100% verdes (Trivy Image zerado e ZAP com 61 PASS).
- **Parcial (50% dos pontos):**
- *No Nível 2:* Corrige 1 ou 2 falhas, mas deixa o Hadolint ou Trivy FS falhando.
- *No Nível 3:* Corrige de 4 a 5 falhas com gates parcialmente verdes, ou corrige no código mas quebra testes existentes.
- **Insuficiente (0% dos pontos):** Não realizou commits, não abriu Pull Request ou manteve os arquivos vulneráveis inalterados.

3. Compreensão do Impacto no Negócio (Tríade CIA)

- **Excelente (100% dos pontos):** Conecta a vulnerabilidade técnica diretamente às consequências financeiras, jurídicas e operacionais do Clube Aurora (multas da ANPD/LGPD, exposição pública de dados de milionários, chantagem).
- **Parcial (50% dos pontos):** Explica a tríade CIA de forma genérica e teórica de livro-texto, sem contextualizar com o serviço de concierge de luxo.
- **Insuficiente (0% dos pontos):** Respostas em branco ou cópia mecânica sem fundamentação.

4. Governança, RBAC & Menor Privilégio

- **Excelente (100% dos pontos):** Recusa com firmeza e elegância o pedido de admin irrestrito feito pelo Tio Armando para a gerente Carla, fundamentando-se no Princípio do Menor Privilégio, Segregação de Funções (SoD) e propondo papéis RBAC adequados.
- **Parcial (50% dos pontos):** Sugere limitar o acesso, mas não fundamenta tecnicamente em SoD/RBAC ou aceita dar permissões excessivas.

- **Insuficiente (0% dos pontos):** Concorda passivamente em conceder admin pleno sem qualquer controle.

5. Clareza, Organização e Evidências

- **Excelente (100% dos pontos):** Relatório entregue em Markdown limpo, sem artefatos corrompidos, com tabelas alinhadas, commits no padrão Conventional Commits e links de repositório e PR plenamente funcionais.
- **Parcial (50% dos pontos):** Documento desorganizado, prints ilegíveis ou commits com mensagens genéricas (`fix` , `teste`).
- **Insuficiente (0% dos pontos):** Entrega ilegível, fora do prazo ou links quebrados (repositório privado sem acesso ao avaliador).

[DAST] Exemplos Práticos de Composição de Nota por Nível

Exemplo 1 Nível 1 (Teórica Guiada)

- **Cenário:** O aluno preencheu todas as seções do `TEMPLATE_TG.md` . Descreveu com profundidade o impacto de um vazamento de SQL Injection na base de clientes VIP do clube, associou corretamente a tríade CIA e redigiu uma resposta exemplar ao Tio Armando explicando SoD e desenhando uma matriz de perfis de acesso.
- **Cálculo da Nota:** Critério 1 (25 pts) + Critério 3 (40 pts) + Critério 4 (25 pts) + Critério 5 (10 pts) = **100 / 100 (Nota A+ / Excelente)**.

Exemplo 2 Nível 2 (Misto)

- **Cenário:** O aluno realizou o fork, desindexou o `.env` com `.gitignore` (F1), atualizou `requirements.txt` (F2) e endureceu o `Dockerfile` com multi-stage e non-root (F4). O job estático ficou verde. No relatório `TEMPLATE_TM.md` , preencheu a matriz STRIDE e o caso de governança.
- **Cálculo da Nota:** Critério 1 (20 pts) + Critério 2 (30 pts) + Critério 3 (20 pts) + Critério 4 (20 pts) + Critério 5 (10 pts) = **100 / 100 (Nota A+ / Excelente)**.
- *Cenário Parcial (se F4 ficou com warning no linter):* Critério 1 (20 pts) + Critério 2 (20 pts) + Critério 3 (20 pts) + Critério 4 (20 pts) + Critério 5 (10 pts) = **90 / 100 (Nota A)**.

Exemplo 3 Nível 3 (Técnica)

- **Cenário Completo:** O aluno corrigiu as 7 falhas no código. Tanto a Pipeline Estática quanto a Dinâmica terminaram 100% verdes no GitHub Actions (Hadolint, Trivy FS, Semgrep, Trivy Image zerado e ZAP com 61 PASS). O PR foi aberto com commits atômicos e o `TEMPLATE_EVIDENCIAS.md` documentou cada evidência.
- **Cálculo da Nota:** Critério 1 (15 pts) + Critério 2 (45 pts) + Critério 3 (10 pts) + Critério 4 (20 pts) + Critério 5 (10 pts) = **100 / 100 (Nota A+ / Excelente)**.
- *Cenário Parcial (resolveu 5 de 7 falhas com rigor e ótima documentação):* Critério 1 (15 pts) + Critério 2 (35 pts) + Critério 3 (10 pts) + Critério 4 (20 pts) + Critério 5 (10 pts) = **90 / 100 (Nota A)**. Entregas parciais bem justificadas são amplamente valorizadas!

Diretrizes de Avaliação na Transição entre Trilhas

1. **Promoção (Upgrade N1 N2 ou N2 N3):**
   - O aluno que começou em uma trilha mais básica e decidiu entregar em uma trilha superior será avaliado **100% pela matriz de pesos da trilha entregue**, sem exigências retroativas.
   - Todo o esforço conceitual desenvolvido anteriormente é aproveitado.

2. **Aterrissagem Segura (Fallback N3 N2 ou N2 N1):**
   - Caso o aluno enfrente bloqueios em falhas dinâmicas complexas no Nível 3 (ex: ZAP ou Compose), ele pode optar por submeter o relatório `TEMPLATE_TM.md` (Nível 2) ou `TEMPLATE_TG.md` (Nível 1).
   - **Garantia Antidesestímulo:** A avaliação será realizada estritamente sob os critérios da trilha entregue, permitindo que o aluno alcance **nota 100 / 100 (Nota A+)** sem qualquer tipo de dedução por ter tentado uma trilha mais avançada.
   - As correções de código já efetuadas (ex: F1, F2, F4) compõem a pontuação prática integral do Nível 2.